Policy 21 – Security & Privacy Awareness Training

1. Table of Contents

1 Document Content Page

2 Policy Objectives and Scope

2.1 Purpose

2.2 Scope

2.3 Training Curriculum

2.4 Onboarding Training

2.5 Ongoing & Role-Based Training

2.6 Phishing & Social-Engineering Exercises

2.7 Training Records & Metrics

3 Policy Compliance

3.1 Compliance Measurement

3.2 Exceptions

3.3 Non-Compliance

3.4 Continual Improvement

2. Policy Objectives and Scope

2.1 Purpose – Equip personnel with knowledge to recognise and respond to security and privacy risks.

2.2 Scope – All employees, contractors, interns, and third-party staff with system access.

2.3 Training Curriculum

- Core topics: data-classification, phishing, password/MFA, incident reporting, privacy basics.

2.4 Onboarding Training

- Complete baseline training within first week of access.
- Sign electronic acknowledgement; system access suspended until completed.

2.5 Ongoing & Role-Based Training

- Provide refresher micro-modules or lunch-and-learns at least annually.
- Deliver specialised modules for engineers (secure coding), support (PII handling), etc.

2.6 Phishing & Social-Engineering Exercises

- Conduct simulated phishing tests quarterly.
- Users who fall for a phish complete remedial training within five business days.

2.7 Training Records & Metrics

- Track completion in HR or LMS system; retain logs three years.
- Report completion rate and phishing-failure rate to management quarterly.

3. Policy Compliance

3.1 Compliance Measurement – ≥ 95 % training completion before due date; phishing failure rate trending downward.

3.2 Exceptions – Short-term deferral allowed for leave of absence; complete training within two weeks of return.

3.3 Non-Compliance – Access restrictions or HR action for repeated failures or missed deadlines.

3.4 Continual Improvement – Revise curriculum based on incident trends, employee feedback, and threat landscape.